국가 · 공공기관 도입 IT보안제품에 대한

국가용 보안요구사항

국가용 보안요구사항은 제품이 구현해야 하는 모든 보안기능이 아닌 기본적으로 만족해야 할 사항을 기술한 문서입니다. 국가정보원은 대상 제품이 다양한 보안위협에 대응하기 위해 국가용 보안요구사항에 기재된 항목뿐 아니라 다양한 보안기능을 추가 구현하여 제품의 보안성을 제고할 것을 적극 권장합니다.

NIS

3편 제품 보안요구사항

가상화제품군

21장 가상화 관리제품

21장
가상화 관리제품 보안요구사항

1절 일반사항

1. 운용 환경 정의

■ 가정사항

○ 제품은 인가된 관리자만이 접근 가능한 물리적으로 안전한 환경에 설치 및 운용된다.

○ 제품의 인가된 관리자는 악의가 없으며, 제품 관리 기능에 대하여 적절히 교육받았고 운용기관이 마련한 관리자 지침에 따라 정확하게 의무를 수행한다.

○ 제품의 인가된 관리자는 감사기록 유실에 대비하여 감사 데이터 저장소의 여유 공간을 주기적으로 확인하고 감사기록이 소진되지 않도록 감사기록 백업(외부 로그서버, 별도 저장장치 등) 등을 수행한다.

○ 제품의 인가된 관리자는 제품 작동에 불필요한 운영체제상의 서비스나 수단 등을 제거하고 취약점에 대한 개선작업을 수행하여 운영체제의 신뢰성과 안전성을 보장한다.

○ 제품의 인가된 관리자는 반드시 필요한 허용 대상만을 설정하고, 사용하지 않는 단말, 사용자 등은 허용 목록에서 삭제하여 잠재적인 취약성이 발생하는 것을 방지해야 한다.

○ 제품의 인가된 관리자는 네트워크 보호를 위해 침입차단시스템, 침입방지시스템, 침입탐지시스템 등의 보안제품을 설치 · 운용한다.

■ 제품 개요

가상화 관리제품은 가상영역에 대한 접근통제, 가상영역 자원에 대한 접근통제 및 사용자 데이터 보호 기능을 수행하는 제품이다. 제품은 일반적으로 관리서버, 에이전트, 클라이언트 등 다양한 형태로 구성된다. 제품은 기관의 중요 데이터에 대한 접근통제 및 보호를 위해 인가된 사용자만이 가상영역에 접속, 가상영역의 자원을 활용하여 사용자 데이터를 가상영역에 저장하기 위한 정보보호제품이다. 제품은 가상화 기술을 통해 논리적으로 분리된 가상 환경에서 가상영역의 자원을 인가된 사용자에게만 제공한다.

■ 운용 환경

제품의 식별 및 인증 대상이 되는 사용자는 관리자 및 일반사용자이다.

■ 공통보안요구사항의 적용

‘서버 공통보안요구사항’과 ‘엔드포인트 공통보안요구사항’을 함께 적용한다.

여 백

2절 보안요구사항

1. 접근 통제

1.1 가상영역 접근통제

1.1.1

필수

제품은 사용자 보안속성에 따라 가상영역의 접근을 허용 또는 차단하는 기능을 제공해야 한다.

요구항목

① 사용자 보안속성은 다음과 같이 이루어 질 수 있으며, 최소한 사용자 인증 상태를 만족하는 경우에만 가상영역의 접근을 허용한다.

- 사용자 인증상태(필수) : 제품의 식별 및 인증을 통해 일반 사용자에 대한 식별 인증 수행.
- 클라이언트 식별정보 : *클라이언트의 IP, MAC 등* 다양한 정보를 기반으로 생성할 수 있다.

점검시 유의사항

① 시험자는 제품의 가상영역 접근에 대한 접근통제 메커니즘을 조사해야 한다.

② 제품이 접근통제 정책 설정 방법에 따라 사용자를 허용 또는 차단하는지 시험해야 한다.

- 제품을 통한 정상적인 접근이 아닌 경우(MSTSC, VNC 등) 차단해야 한다.

③ 가상영역 접근은 최소한 사용자 인증상태가 만족하는 경우에만 허용되는지 확인해야 한다.

④ 시험자는 구동되는 하이퍼바이저 종류, 버전 등 형상을 식별하고 시험결과 보고서에 명시해야 한다.

1.2 가상영역 자원 접근통제

1.2.1

필수

제품은 사용자가 가상영역내 인가된 자원에 접근할 경우 설정된 접근통제 규칙에 따라 접근통제를 수행해야 한다.

요구항목

① 다음 기능과 관련된 가상영역내 자원은 필수로 통제되어야 한다.

- *IP 변경 등* 네트워크 설정.
- *폴더 공유 등* 폴더 설정.
- *파일 실행 등* 파일 설정.

② 제품이 기본적으로 제공해야 하는 최소 보안관리 기능은 〈표 1〉과 같다.

점검시 유의사항

① 가상영역 자원 접근에 대한 접근통제 메커니즘을 조사해야 한다.

② 가상영역 자원에 대한 접근통제 정책에 따라 허용 · 차단되는지 시험해야 한다.

③ 접근통제 기능은 제품에 구현되거나 운영환경에서 제공하는 신뢰할 수 있는 디렉토리 서비스(Directory Service)를 이용할 수 있다.

- 신뢰할 수 있는 디렉토리 서비스의 예로써 Active Directory® 등이 있다.

2. 사용자 데이터 보호

2.1 가상영역 데이터 유출방지

2.1.1

필수

가상영역 데이터의 인가되지 않은 유출을 방지하기 위해 가상영역 화면 캡쳐, 가상영역 키로깅에 대한 통제 기능을 제공해야 한다.

점검시 유의사항

① 가상영역의 데이터 유출 통제 메커니즘을 조사해야 한다.

② 사용자가 실제영역(사용자PC)에서 가상영역의 화면을 캡처하지 못하는지 확인해야 한다.

- 가상화 구동 중 원격 접속을 차단해야 한다.

③ 사용자가 가상영역에 입력된 키 값을 실제영역에서 키로깅이 되지 않는지 확인해야 한다.

3. 보안관리

3.1 자원 접근통제 규칙 관리

3.1.1

필수

제품은 인가된 관리자만이 보안관리 기능을 수행할 수 있도록 제한해야 한다.

요구항목

① 보안관리 기능에 해당되는 것은 〈표 1〉과 같다.

〈 표 1. 최소 보안관리 기능 항목 〉

보안기능	보안관리 기능	비고
자원 접근통제	사용자 및 사용자 그룹에게 가상영역 할당, 수정, 삭제	
	가상영역 자원(CPU, Memory, HDD) 할당, 수정, 삭제	
	가상머신 시작, 중지, 종료, 재시작	
	가상영역 생성, 설정, 삭제	
	가상머신 스냅샷	기능 제공시
	가상머신 리소스 모니터링	기능 제공시
	설치, 실행 가능한 어플리케이션 설정	기능 제공시

자원 접근통제	사용자별 가상영역 백업 및 복구	기능 제공시
	사용자에게 전달되는 공지사항 생성, 수정, 삭제	기능 제공시
	사용자에게 최신버전의 클라이언트 확인	기능 제공시
	가상머신 연결이름, IP, 포트 할당, 수정, 삭제	기능 제공시
	가상영역 내 매체제어(USB · 프린터 사용 등) 허용, 차단	기능 제공시

4. 오류 발생 통보

4.1 오류 발생 통보

4.1.1

필수

제품은 가상영역내 시스템의 비정상적인 오류 발생을 탐지한 경우, 관리자에게 보안경보를 통보해야 한다.

요구항목

① 보안경보의 예는 다음과 같다.

- *화면 알람, 관리자 이메일 발송 등*

점검시 유의사항

① 가상영역의 OS 오류 중 관리자가 설정한 오류 이상의 로그가 발생할시 보안경보가 발생하는지 확인해야 한다.

끝.

여 백

〈 별 표 〉

제 · 개정 이력

일 자	주요 변경 내용	문서 버전
2021. 4. 2.	‘가상화 관리제품 보안요구사항’으로 개정	V3.0
2021. 9. 1.	o 다음 보안기능의 요구사항을 변경 - 1.2.1 : (변경내용)신뢰할 수 있는 외부 IT실체가 제공하는 접근통제 기능 활용 가능	V3.1